SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A2-Vulnerability Assessment Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
REg.no	192411156	**Name of the Student**	K.Hema Sree

Co2: Identify common network attacks and analyze threat intelligence sources and data collection techniques.

Code of Conduct:

I, Keerthipati Hema Sree, 192411156 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of Student

K. Hema

A2-Vulnerability Assessment Report

Q1. Explain the common types of network attacks: malware, phishing, DoS and DDoS. Give one example and one preventive measure for each. (10 marks)
Key points: malware types (virus, worm, trojan, ransomware, spyware); phishing via deceptive emails, links or sites to steal credentials; DoS from a single source versus DDoS from a botnet; preventive measures such as antivirus, user awareness training, rate limiting, firewalls and CDN or traffic scrubbing.

Q2. What is a Man-in-the-Middle (MitM) attack? Describe how it works and the techniques used to carry it out, and list the countermeasures. (8 marks)
Key points: the attacker intercepts and may alter communication between two parties; techniques include ARP poisoning, rogue Wi-Fi access points, DNS spoofing and session hijacking; countermeasures include HTTPS/TLS, VPN, certificate validation, HSTS and dynamic ARP inspection.

Q3. Differentiate between spoofing and sniffing. Describe the types of spoofing and explain how sniffing can be detected or prevented. (8 marks)
Key points: spoofing is forging identity (IP, MAC, email or DNS spoofing); sniffing is passively capturing packets (Wireshark, tcpdump) and mainly exposes unencrypted data; prevention includes encryption, switched networks, port security and anti-spoofing filters.

Q4. Define vulnerability assessment. Explain its steps and describe the contents of a good vulnerability assessment report. (8 marks)
Key points: the process is asset identification, scanning (Nessus, OpenVAS), analysis, risk rating and reporting; the report contains an executive summary, scope and methodology, findings with CVE IDs, CVSS severity scores, evidence, risk impact and prioritized remediation recommendations; also mention how it differs from penetration testing.

Q5. What is Open-Source Intelligence (OSINT)? Discuss the common threat data sources and the techniques used to collect threat data. (8 marks)
Key points: OSINT draws on public sources such as WHOIS, Shodan, social media, news, forums, code repositories and the CVE/NVD databases; also cover commercial and internal sources (logs, honeypots) and collection techniques such as passive collection, web scraping and DNS or domain lookups; mention legal and ethical considerations.

Q6. What are Indicators of Compromise (IoCs)? Explain the types of IoCs and describe how threat feeds help organizations improve their defense. (8 marks)
Key points: IoCs are artifacts such as file hashes, malicious IPs, domains, URLs, registry keys and unusual network traffic; threat feeds (open-source or commercial, in formats like STIX/TAXII) deliver them for SIEM or firewall blocking and faster detection; limitations include false positives, stale data and the need for context.

Answers

Q1. Common Types of Network Attacks (10 marks)

A network attack is an attempt to gain unauthorised access to, disrupt, steal from or damage a network, its systems or its data. The four common categories are below.

1. Malware

Definition: Malicious software designed to damage, disrupt, spy on or gain unauthorised control of a system.

Type	Behaviour	Spread
Virus	Attaches to a host file and runs when the file is executed	Infected files, USB drives, email attachments
Worm	Self-replicating; needs no host file or user action	Network vulnerabilities, email, shared folders
Trojan	Appears as legitimate software but hides malicious functions; opens backdoors	Fake installers, cracked software, attachments
Ransomware	Encrypts files and demands payment for the key	Phishing, exposed RDP, unpatched systems
Spyware	Secretly records keystrokes, browsing and credentials	Bundled freeware, drive-by downloads

Example: WannaCry (2017) was ransomware with worm-like behaviour. It exploited the SMB vulnerability EternalBlue to spread across networks and encrypt files.

Preventive measures: Up-to-date antivirus/EDR, timely patching, application whitelisting, regular offline backups, and avoiding untrusted downloads.

2. Phishing

Definition: A social-engineering attack in which the attacker sends deceptive emails, messages, links or fake websites that imitate a trusted entity, in order to steal credentials, financial data or deliver malware.

How it works: The attacker crafts a convincing message with an urgent pretext (e.g. "your account will be locked"). The victim clicks a link to a cloned login page or opens a malicious attachment. The credentials or access are then harvested and misused.

Variants: spear phishing (targeted), whaling (executives), vishing (voice), smishing (SMS), clone phishing.

Example: A fake bank email asking the user to "verify" their account at a look-alike URL, which captures the username, password and OTP.

Preventive measures: User awareness training and phishing simulations, email filtering (SPF, DKIM, DMARC), multi-factor authentication, and checking URLs and sender addresses before acting.

3. Denial of Service (DoS)

Definition: An attack from a single source that floods or crashes a target so that legitimate users cannot access the service.

Example: A ping flood / SYN flood from one machine that exhausts the server's connection queue or bandwidth.

Preventive measures: Firewalls and IPS to block the offending source, rate limiting, and patching services against crash-type vulnerabilities.

4. Distributed Denial of Service (DDoS)

Definition: A DoS attack launched from many compromised devices (a botnet) at the same time, making the volume enormous and the source hard to block.

Example: The Mirai botnet (2016) used hacked IoT devices (cameras, routers) to attack DNS provider Dyn, disrupting major websites.

Preventive measures: CDN and traffic-scrubbing services, rate limiting, load balancing and over-provisioned bandwidth, and anycast routing.

Basis	DoS	DDoS
Source	Single machine	Many machines (botnet)
Volume	Lower	Very high
Blocking	Easy (block one IP)	Difficult

Q2. Man-in-the-Middle (MitM) Attack (8 marks)

Definition: In a MitM attack, the attacker secretly positions themselves between two communicating parties, intercepting and possibly altering the communication while both sides believe they are talking directly to each other.

How it works:

1. **Interception: The attacker gets into the communication path (e.g. by spoofing or controlling the network).**

2. **Relay: Traffic is forwarded between the victim and the real server so that everything appears normal.**

3. **Exploitation: The attacker reads, records or modifies data (passwords, banking details, session cookies) in transit.**

Techniques:

- **ARP poisoning: Forged ARP replies link the attacker's MAC address to the gateway's IP, so LAN traffic flows through the attacker.**
- **Rogue Wi-Fi access point / evil twin: A fake hotspot with a trusted-looking name captures all traffic of connected users.**
- **DNS spoofing: Forged DNS responses redirect the victim to a malicious site that looks genuine.**
- **Session hijacking: The attacker steals a session ID or cookie and takes over an authenticated session.**
- **SSL stripping: HTTPS is downgraded to HTTP so data is sent in plain text.**

Countermeasures:

- **HTTPS/TLS for end-to-end encryption.**
- **VPN on untrusted networks.**
- **Certificate validation (and certificate pinning) so impersonators are detected.**
- **HSTS to force HTTPS and block SSL stripping.**
- **Dynamic ARP Inspection (DAI) and static ARP entries on switches.**
- **DNSSEC, WPA2/WPA3 Wi-Fi security, multi-factor authentication, and secure cookies with short session lifetimes.**
- **User awareness: avoid public Wi-Fi for sensitive tasks and never ignore certificate warnings.**

Q3. Spoofing vs Sniffing (8 marks)

Basis	Spoofing	Sniffing
Nature	Active: forges identity or data	Passive: captures and reads traffic

Basis	Spoofing	Sniffing
Aim	Impersonate a trusted entity to gain access or deceive	Eavesdrop to collect information
Network impact	Injects false packets	Usually does not alter traffic, hard to detect
Main threat to	Authentication and trust	Confidentiality

Types of Spoofing

- **IP spoofing: Forged source IP in packet headers, used in DDoS reflection attacks and to bypass IP-based trust.**
- **MAC spoofing: Changing the MAC address to impersonate a device or bypass MAC filtering.**
- **ARP spoofing: Fake ARP messages that tie the attacker's MAC to another host's IP, enabling MitM.**
- **Email spoofing: Forged "From" address to make a phishing email appear to come from a trusted sender.**
- **DNS spoofing (cache poisoning): False DNS records redirect users to malicious sites.**

Sniffing

Sniffing is passively capturing network packets using tools such as Wireshark or tcpdump. It mainly exposes unencrypted data (HTTP, FTP, Telnet, SMTP credentials). Network cards in promiscuous mode on hubs or Wi-Fi networks can capture traffic not meant for them.

Detecting Sniffing

- **Scan for NICs in promiscuous mode (e.g. with Nmap scripts or sniffer-detection tools).**
- **Monitor for ARP anomalies, duplicate MAC/IP mappings and sudden ARP floods (e.g. with arpwatch).**
- **Use IDS/IPS to flag suspicious traffic redirection.**
- **Look for unexpected devices on the network and rogue taps.**

Preventing Sniffing and Spoofing

- **Encryption: HTTPS, SSH, SFTP, VPN and WPA3 so captured data is unreadable.**
- **Switched networks instead of hubs, and VLAN segmentation.**
- **Port security: limit MAC addresses per port and disable unused ports.**
- **Dynamic ARP Inspection and DHCP snooping.**
- **Anti-spoofing filters: ingress/egress filtering (BCP 38), reverse-path checks, and SPF/DKIM/DMARC for email.**
- **Secure physical access to network equipment.**

Q4. Vulnerability Assessment (8 marks)

Definition: Vulnerability assessment (VA) is the systematic process of identifying, classifying and prioritising security weaknesses in systems, networks and applications so that they can be fixed before attackers exploit them.

Steps

1. **Planning and scoping: Define objectives, scope, permissions and schedule.**
2. **Asset identification: Discover hosts, services, operating systems, applications and their criticality.**
3. **Vulnerability scanning: Use automated tools such as Nessus, OpenVAS, Qualys (and Nmap for discovery) to detect known flaws, misconfigurations and missing patches.**
4. **Analysis: Verify findings manually, eliminate false positives and correlate with threat information.**
5. **Risk rating: Assign severity using CVSS plus asset value and exploitability.**
6. **Reporting: Document findings and recommendations.**
7. **Remediation and re-scan: Patch or mitigate, then verify the fix.**

Contents of a Good VA Report

1. **Executive summary: Non-technical overview of overall risk, key findings and business impact.**
2. **Scope and methodology: Systems assessed, dates, tools, scan type (credentialed/uncredentialed) and limitations.**
3. **Findings: For each vulnerability: description, affected asset(s), CVE ID, and CVSS severity score.**

4. **Evidence: Screenshots, scan output or proof of detection.**
5. **Risk and impact: What an attacker could achieve and the likelihood of exploitation.**
6. **Prioritised remediation recommendations: Specific fixes (patches, configuration changes, workarounds) ordered by risk, with suggested timelines.**
7. **Appendices: Raw data, tool details, references and a retest plan.**

VA vs Penetration Testing

Basis	**Vulnerability Assessment**	**Penetration Testing**
Goal	**Identify and list weaknesses**	**Exploit weaknesses to prove real impact**
Method	**Mostly automated scanning**	**Manual, skill-driven attack simulation**
Scope	**Broad coverage**	**Deep, targeted**
Frequency	**Regular/continuous**	**Periodic**
Output	**Ranked list of vulnerabilities**	**Demonstrated attack paths and compromise**

Q5. Open-Source Intelligence (OSINT) and Threat Data (8 marks)

OSINT: Intelligence gathered, analysed and used from publicly available information (legally accessible without breaking into systems) to support security decisions, such as profiling threats, attack surface and attackers.

Common Threat Data Sources

Open-source (public):

- **WHOIS and DNS records: domain ownership and infrastructure.**
- **Shodan / Censys: exposed devices and services.**
- **Social media, news and forums: attacker chatter, breach announcements.**
- **Code repositories (GitHub): leaked keys, credentials and exploit code.**
- **CVE / NVD databases: disclosed vulnerabilities and scores.**
- **Paste sites and breach databases (e.g. Have I Been Pwned), and malware repositories such as VirusTotal and abuse.ch.**

Commercial sources: Paid intelligence services (e.g. Recorded Future, Mandiant, CrowdStrike) giving curated, enriched and timely data with analyst support.

Internal sources: Firewall, IDS/IPS, proxy, DNS and endpoint logs, SIEM data, past incident reports, and honeypots that attract attackers and record their behaviour.

External sharing sources: CERT advisories and ISACs (industry sharing groups).

Collection Techniques

- **Passive collection: Gathering information without touching the target (search engines, public records, archived pages), which leaves no trace.**
- **Web scraping / crawling: Automated extraction from websites, forums and paste sites.**
- **DNS and domain lookups: WHOIS, reverse DNS, subdomain enumeration and certificate-transparency logs.**
- **Search-engine techniques: Advanced operators ("Google dorking").**
- **Tools: Maltego, theHarvester, Recon-ng, SpiderFoot and Shodan.**
- **Honeypots and log analysis for internal collection.**
- **Correlation and analysis: Filtering, verifying and combining data to turn it into actionable intelligence.**

Legal and Ethical Considerations

- **Use only publicly accessible data and respect laws (privacy and data-protection rules, computer-misuse laws).**
- **Obey website terms of service and avoid unauthorised access or deceptive social engineering.**
- **Handle personal data responsibly, verify the reliability of sources, and avoid misuse of the information collected.**

Q6. Indicators of Compromise (IoCs) and Threat Feeds (8 marks)

Definition: IoCs are forensic artefacts observed on a network or system that indicate a probable intrusion or malicious activity.

Types of IoCs

Type	Examples
File-based	Malicious file hashes (MD5/SHA-256), suspicious file names/paths, malicious attachments, modified system files
Network-based	Malicious IP addresses, domains and URLs; connections to C2 servers; beaconing; unusual traffic volume; abnormal DNS requests
Host-based	Suspicious registry keys, new services or scheduled tasks, unknown processes, unexpected admin accounts, odd login times
Email/behavioural	Spoofed sender domains, phishing subject lines, unusual privilege escalation or large data transfers

How Threat Feeds Improve Defence

A threat feed is a continuous stream of threat data (malicious IPs, domains, URLs, hashes) from open-source (AlienVault OTX, abuse.ch) or commercial providers, often shared in standard formats such as STIX (the language) and TAXII (the transport protocol).

Benefits:

- **Automated blocking: IoCs are loaded into firewalls, proxies, IPS and DNS filters to block known bad infrastructure.**
- **Faster detection: SIEM and EDR tools match logs and files against feed indicators to raise alerts quickly.**
- **Proactive defence: Organisations learn about emerging campaigns before being hit.**
- **Incident response support: Analysts search for IoCs to scope and contain a breach.**
- **Collaboration: Sharing through STIX/TAXII and ISACs strengthens the wider community.**

Limitations

- **False positives and noise can overwhelm analysts.**
- **Stale data: IPs and domains change quickly, so indicators expire.**
- **Lack of context: An indicator alone doesn't show relevance, severity or attacker intent.**

- **Variable quality and cost (for commercial feeds), requiring validation and analyst effort.**

Conclusion: IoCs and threat feeds are most effective when combined with internal telemetry, context and regular tuning.